

Riscos e Segurança na Integração de Sistemas Legados

Desafios de segurança e estratégias de mitigação para ambientes legados e modernos.

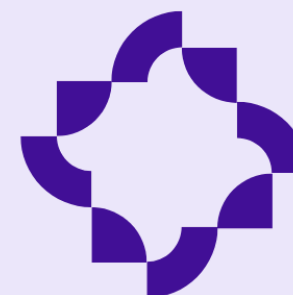
INSTITUIÇÃO EXECUTORA

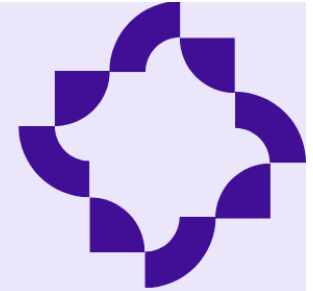


COORDENADORA



APOIO





Sumário

- Sistemas Legados e Motivações de Integração
- Vulnerabilidades e Riscos Críticos em EOL
- Desafios de Identidade e Observabilidade
- Expansão da Superfície de Ataque e Soluções
- Workflow de Integração Segura e Monitoramento



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO

MINISTÉRIO DA
CIÊNCIA, TECNOLOGIA
E INOVAÇÃO

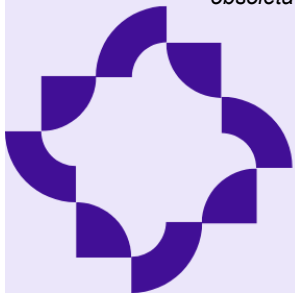




Computadores GEC 4000: exemplos de tecnologia obsoleta em sistemas legados.

Sistemas Legados e Integração

- **Tecnologia Obsoleta:** Utilizam linguagens de programação antigas (ex: COBOL, Fortran) ou sistemas operacionais que já não possuem suporte técnico ou atualizações do fornecedor.
- **Arquitetura Monolítica:** Possuem estrutura rígida e centralizada, o que dificulta a escalabilidade horizontal e inviabiliza a adoção de arquiteturas mais flexíveis, como microsserviços ou serverless.
- **Dependência de Negócio:** São responsáveis por regras de negócio extremamente complexas e, muitas vezes, críticas para a operação da empresa, porém tais regras raramente estão documentadas ou mapeadas.
- **Desafios de Segurança:** Apresentam vulnerabilidades devido à falta de patches de segurança, além de serem incompatíveis com padrões de criptografia atuais (ex: TLS 1.3), expondo a organização a riscos de violação de dados.



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO





Motivações da Integração Legada

Interoperabilidade Essencial

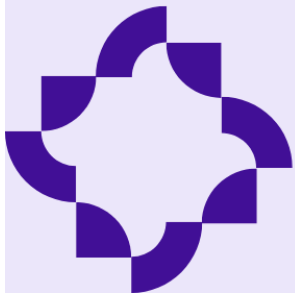
Conectar **bases de dados históricas** com *front-ends* modernos (Web/Mobile) é crucial para manter a funcionalidade e o acesso aos dados existentes, garantindo que sistemas legados não se tornem silos de informação isolados da inovação.

Análise de Negócios (BI)

A **extração de dados** de sistemas legados é vital para análises em tempo real e para alimentar modelos de *Machine Learning*. Isso permite insights mais profundos e tomada de decisão estratégica baseada em um histórico de informações robusto.

Eficiência Operacional

A **automação de processos** entre sistemas legados e novas aplicações elimina a entrada manual de dados, reduzindo erros e liberando recursos. Isso otimiza o fluxo de trabalho e aumenta significativamente a produtividade da equipe.



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO

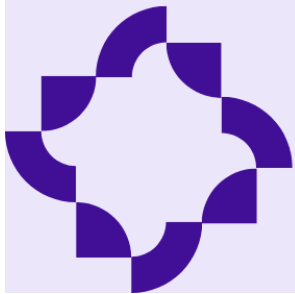
MINISTÉRIO DA
CIÊNCIA, TECNOLOGIA
E INOVAÇÃO





Vulnerabilidades em Sistemas EOL

- **Falta de Patches:** Vulnerabilidades conhecidas permanecem abertas indefinidamente, pois não há mais suporte ou atualizações de segurança para esses sistemas.
- **Protocolos Inseguros:** Frequentemente, o uso de Telnet, FTP ou HTTP sem criptografia é mantido devido a limitações de hardware ou software legados.
- **Hardcoded Credentials:** Práticas de desenvolvimento antigas comumente expõem credenciais (senhas ou chaves) diretamente no código-fonte, um risco elevado de segurança.
- **Incompatibilidade de Ciphers:** Sistemas EOL podem não suportar algoritmos modernos de hashing (como Argon2 ou BCrypt), comprometendo a robustez da criptografia.



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO

MINISTÉRIO DA
CIÊNCIA, TECNOLOGIA
E INOVAÇÃO

Prevalência de Riscos Críticos



- **Falhas de Configuração:** Constituem 35% dos incidentes, frequentemente decorrentes de exposição de APIs sem proteção adequada.
- **Autenticação Fraca:** Responsável por 25% dos problemas, onde sistemas legados falham em suportar MFA ou protocolos modernos.
- **Vulnerabilidades Não Corrigidas:** Atingem 20%, sublinhando a importância da falta de atualizações no *core* legado.
- **Outros:** Os 20% restantes incluem deficiências em logs e monitoramento, essenciais para detecção de anomalias.

Gráfico de pizza ilustrando a prevalência de riscos críticos



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO





Prevalência de Riscos Críticos

- **Fórmula do Risco:** $R = P(V) \times I$
- **Onde:**
 - **R** = Risco total da integração.
 - **P(V)** = Probabilidade de que a vulnerabilidade identificada seja efetivamente explorada por um agente ameaçador.
 - **I** = Impacto estimado para o negócio, caso a exploração ocorra (considerando perdas financeiras, operacionais, reputacionais, etc.).

Gráfico de pizza ilustrando a prevalência de riscos críticos



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



Desafios de Identidade (IAM)



Protocolos Antigos de Autenticação

Sistemas legados frequentemente utilizam *protocolos de autenticação* limitados, como **LDAP básico**, **NTLM** ou métodos de autenticação baseados em formulários locais. Estes podem não ser compatíveis com padrões de segurança modernos.



Protocolos Modernos Necessários

A integração moderna exige suporte a padrões como **OAuth2**, **OpenID Connect** (OIDC) e **SAML 2.0** para permitir o Single Sign-On (SSO) e garantir uma gestão de identidade mais robusta e interoperável.



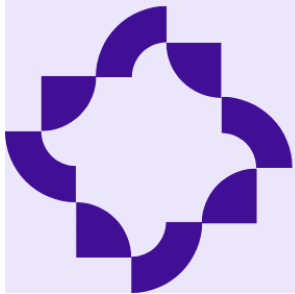
Riscos de Autenticação Quebrada

A *gestão de identidade e acesso* (IAM) é um ponto crítico. Falhas como **autenticação quebrada** (*Broken Authentication*) permitem o sequestro de sessões e contas devido a vulnerabilidades na validação ou manutenção de sessões de usuário.



Dificuldade em Menor Privilégio

Sistemas legados podem dificultar a implementação do **Princípio do Menor Privilégio** devido à falta de granularidade nas permissões. Isso leva a **privilegios excessivos**, aumentando a superfície de ataque em caso de comprometimento.



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO





Ponto Cego: Observabilidade

Logs Incompletos

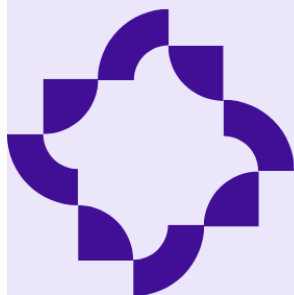
Registros que não capturam o IP de origem, o *payload* da requisição ou o contexto do usuário, impossibilitando a auditoria completa e eficaz de incidentes de segurança.

Ausência de Tracing

A impossibilidade de rastrear uma transação que atravessa do microserviço moderno para o *mainframe* antigo cria **silos de dados** e dificulta a investigação de fluxos de dados complexos.

Deteção Tardia

Ataques de exfiltração de dados podem passar despercebidos por meses devido à falta de alarmes em tempo real e telemetria inadequada, resultando em respostas reativas e lentas.



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



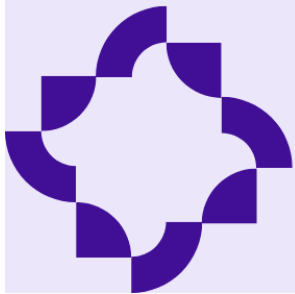


Sistema Isolado

Operava em uma **rede interna fechada** (*air-gapped*), com risco predominantemente interno e físico. A segurança dependia de firewalls de rede perimetrais, com menor exposição a ameaças externas.

Sistema Integrado

A integração via APIs e Gateways expande a **superfície de ataque**, expondo-o a ameaças como Injeção de SQL, DoS e Cross-Site Scripting. A camada de mediação deve ser robusta, e o legado pode enfrentar pressões de tráfego não dimensionadas.



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



Estratégias de Integração Segura



Adapter & Wrapper

Encapsula o sistema legado em uma interface moderna. O *Wrapper* (adaptador) traduz chamadas REST para os protocolos internos do legado, permitindo que apenas dados validados entrem.

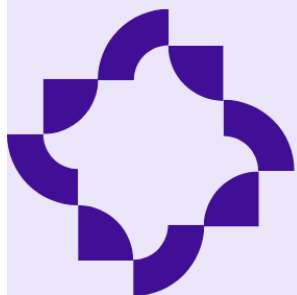


API Gateway

Atua como um **escudo**, gerenciando autenticação, *rate limiting* e sanitização de tráfego antes que ele atinja o legado, protegendo contra exposição direta.

Anti-Corruption Layer (ACL)

Garante que o *design* do novo sistema não seja 'contaminado' por falhas ou modelos de dados obsoletos do sistema legado, mantendo a integridade do novo sistema.



INSTITUIÇÃO EXECUTORA



COORDENADORA

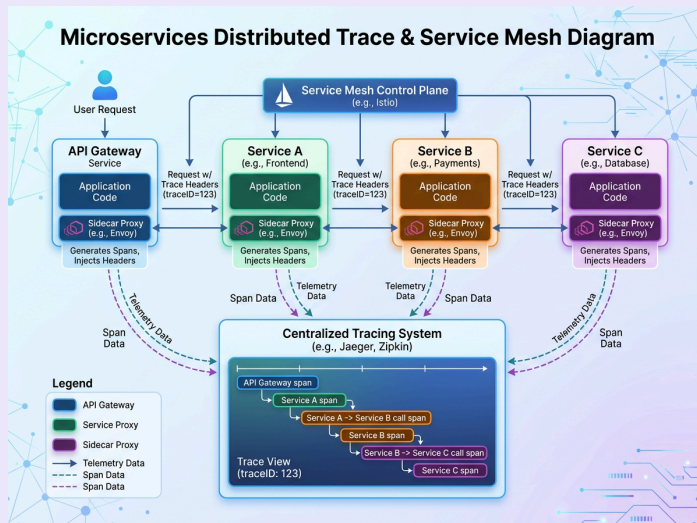


APOIO

MINISTÉRIO DA
CIÊNCIA, TECNOLOGIA
E INOVAÇÃO

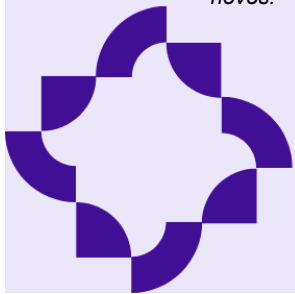


O Papel do API Gateway



API Gateway: segurança e integração entre sistemas legados e novos.

- O Gateway é a peça central da segurança na borda entre o novo e o velho, oferecendo **Offloading de Segurança** ao lidar com a descryptografia TLS e verificação de tokens JWT, poupando o legado de processamento pesado.
- Para proteger sistemas legados sensíveis de quedas por excesso de requisições (Denial of Service), ele aplica **Throttling e Quotas**.
- A **Data Transformation** permite que o Gateway converta JSON para XML ou formatos binários proprietários de forma segura, validando o esquema dos dados.
- Por fim, a **WAF Integration** aplica regras de Web Application Firewall para bloquear padrões de ataque conhecidos.



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO





Workflow de Integração Segura

1

Avaliar Vulnerabilidades

Realizar um levantamento completo para **identificar falhas** de segurança conhecidas e potenciais vetores de ataque presentes no sistema legado, essencial para entender os riscos inerentes.

2

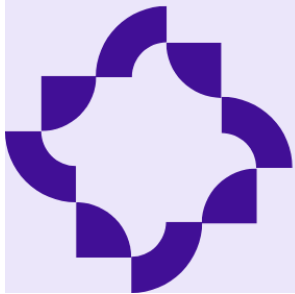
Isolar Rede Legada

Alocar o sistema legado em uma **VLAN restrita**, configurando regras de firewall para permitir tráfego somente do Middleware/Gateway. Isso minimiza a superfície de ataque e o acesso direto.

3

Implementar Wrapper Seguro

Desenvolver a camada de *wrapper* (invólucro) que atuará como tradutor e validador. Esta camada deve **higienizar e validar todos os inputs** antes de interagir com o legado, protegendo contra injeção de código e outros ataques.



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO





Workflow de Integração Segura

4

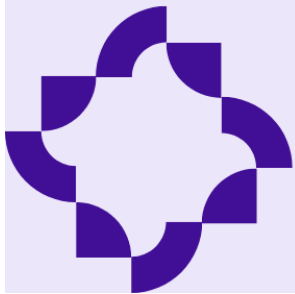
Monitorar e Auditar

Configurar sistemas de **logs centralizados** para registrar todas as interações e eventos entre o Wrapper, Gateway e o sistema legado. Isso permite a correlação de eventos e a detecção precoce de anomalias.

5

Definir Plano Contingência

Estabelecer um '**Kill Switch**' ou procedimentos de desconexão rápida para toda a integração. Em caso de detecção de atividades maliciosas ou anomalias críticas, a integração pode ser interrompida imediatamente para conter danos.



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



Monitoramento e Detecção de Drifts



Escudo de cibersegurança protege redes digitais e dados.

Análise Comportamental

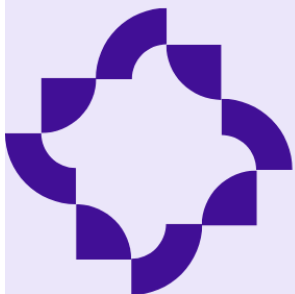
Monitorar o comportamento padrão (baseline) do sistema legado para identificar desvios (drifts) que possam indicar comprometimento. A detecção de anomalias permite uma resposta rápida a ameaças internas e externas.

SIEM e SOC

Integrar os logs de segurança do Gateway de Integração e dos sistemas legados em plataformas de *Security Information and Event Management* (SIEM). Isso proporciona visibilidade unificada e correlaciona eventos para análise pelo *Security Operations Center* (SOC).

Gestão de Mudanças

Estabelecer processos rigorosos de gestão de mudanças para qualquer modificação nos sistemas legados. É crucial validar que tais alterações não invalidem as premissas de segurança ou introduzam novas vulnerabilidades na camada de integração.



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



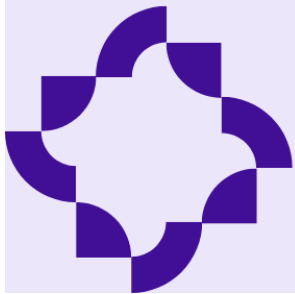
MINISTÉRIO DA
CIÊNCIA, TECNOLOGIA
E INOVAÇÃO





Estudo de Caso: Setor Financeiro

Um banco enfrentou o desafio de integrar os saldos de contas de um Mainframe legado, com mais de 30 anos de uso, a um novo aplicativo móvel. Como o sistema antigo utilizava comunicação via sockets TCP puros, sem qualquer camada de criptografia, a solução adotada foi a implementação de um Micro-Gateway em container, atuando no padrão Sidecar, para realizar o tunelamento TLS entre as pontas. Essa abordagem resultou em uma redução de 90% da superfície de ataque e garantiu a conformidade com as exigências da LGPD (Lei Geral de Proteção de Dados) e as regulamentações do Bacen (Banco Central).



INSTITUIÇÃO EXECUTORA



COORDENADORA



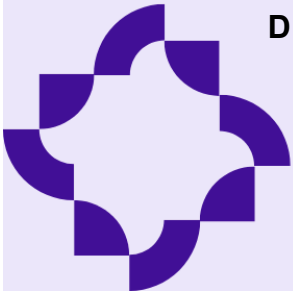
APOIO





Qual é a principal função de uma 'Anti-Corruption Layer' (ACL) em um projeto de integração de sistemas legados?

- A Criptografar os dados em repouso dentro do sistema legado.
- B Aumentar a velocidade de processamento do banco de dados legado.
- C Impedir que os modelos de dados e semânticas obsoletas do legado comprometam o design do novo sistema.
- D Substituir completamente o sistema legado por um novo banco de dados em nuvem.



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO





Qual é a principal função de uma 'Anti-Corruption Layer' (ACL) em um projeto de integração de sistemas legados?

- ✗ Criptografar os dados em repouso dentro do sistema legado.
- ✗ Aumentar a velocidade de processamento do banco de dados legado.
- ✓ Impedir que os modelos de dados e semânticas obsoletas do legado comprometam o design do novo sistema.
- ✗ Substituir completamente o sistema legado por um novo banco de dados em nuvem.



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO

MINISTÉRIO DA
CIÊNCIA, TECNOLOGIA
E INOVAÇÃO

DO LADO DO POVO BRASILEIRO



Discuta com o colega ao lado

Considerando os riscos de segurança e os custos de manutenção, em que ponto a substituição completa (Rip and Replace) de um sistema legado se torna mais vantajosa do que a integração?

Reflitam sobre cenários técnicos e financeiros que justificariam cada abordagem.

INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO

MINISTÉRIO DA
CIÊNCIA, TECNOLOGIA
E INOVAÇÃO





Checklist de Segurança Final

Este checklist detalha ações essenciais para fortalecer a segurança na integração de sistemas legados e aplicações modernas.

Categoria	Ação Necessária	Prioridade
Autenticação	Implementar OAuth2/OIDC no Gateway	Crítica
Tráfego	Habilitar TLS 1.2+ em todos os saltos	Alta
Dados	Validar Schema de entrada e saída (JSON/XML)	Alta
Monitoramento	Centralizar logs no SIEM com Correlation ID	Média
Resiliência	Configurar Circuit Breaker para chamadas ao legado	Média



INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO



Conclusão

- Sistemas legados em EOL expõem organizações a 35% de falhas de configuração e 25% de autenticação fraca, exigindo mitigação proativa.
- Protocolos antigos como LDAP e falta de MFA em legados criam "Broken Authentication" e privilégios excessivos, ampliando vetores de ataque.
- A integração expande a superfície de ataque; API Gateways, Wrappers e ACLs são críticos para isolar o legado da exposição direta.
- O monitoramento contínuo com SIEM e análise de comportamento detectam desvios, sendo vital para conformidade (LGPD/Bacen) e resiliência operacional.

INSTITUIÇÃO EXECUTORA



COORDENADORA



APOIO

MINISTÉRIO DA
CIÊNCIA, TECNOLOGIA
E INOVAÇÃO